Report ITSCTF1

CTF interna — Capture The Flag su infrastruttura virtuale

Penetration Test Report

Host target	`172.20.129.89`
Ambiente	`VM in rete locale isolata (VMware)`
Obiettivo	`Ottenere accesso e flag utente/root tramite escalation privilegi`
Esito	`Compromissione completa (root)`

1. Introduzione

ITS ha allestito una CTF (Capture The Flag) su una macchina virtuale interna alla propria rete. Ogni partecipante ha dovuto installare la VM tramite VMware e collegarla alla rete dedicata. Non era fornita alcuna credenziale di accesso: l'obiettivo della challenge consisteva nel trovare autonomamente la password dell'host per potervi accedere.

`Host target:  172.20.129.89`

2. Ricognizione (Information Gathering)

La fase iniziale è stata condotta con una scansione nmap, al fine di individuare i servizi esposti, il sistema operativo e le relative versioni.

2.1 Risultati della scansione nmap

```
Porte aperte:
  22/tcp    ssh     OpenSSH 9.2p1
  5236/tcp  http    Apache httpd 2.4.68

Sistema operativo stimato: Linux 4.15 - 5.19
```

Successivamente è stata eseguita una scansione con nuclei per individuare rapidamente eventuali CVE note associate ai servizi rilevati, senza tuttavia ottenere riscontri utili.

3. Enumerazione del servizio web

Esplorando l'host tramite browser è emerso un sito di tipo blog, incentrato su tematiche di tecnologia e sicurezza informatica.

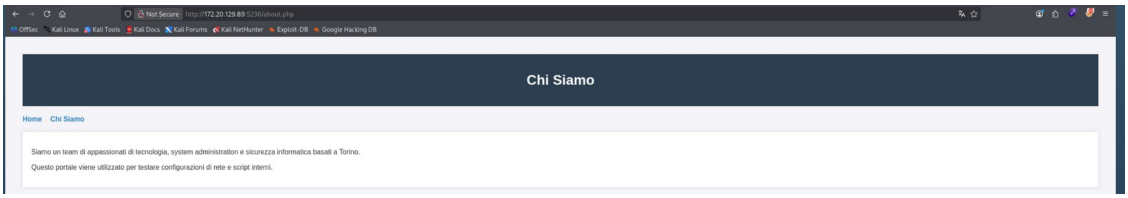


Figura 1 — Pagina "Chi Siamo" del portale esposto su about.php

Analizzando gli endpoint è emerso l'utilizzo di pagine PHP (ad es. about.php), suggerendo un backend dinamico. È stata quindi condotta un'enumerazione con gobuster, includendo l'estensione .php tra i parametri di ricerca, al fine di scoprire ulteriori endpoint non collegati pubblicamente.

Endpoint individuati:

`about.php` e `portal.php`

La pagina portal.php consente di visualizzare, tramite un parametro, il contenuto di file quali /var/www/html/about.php oppure index.html: un comportamento potenzialmente sfruttabile per la lettura arbitraria di file dal filesystem.

4. Sfruttamento della vulnerabilità (Local File Inclusion)

Analizzando la richiesta tramite Burp Suite è stato individuato il parametro responsabile della selezione del file da visualizzare (file_path), passato direttamente nel form della pagina portal.php.



Figura 2 — Codice sorgente della risposta: il form invia il percorso completo tramite il parametro file_path

Da questa osservazione si è dedotto che il parametro potesse essere manipolato per leggere file arbitrari del filesystem del server, non limitandosi a quelli previsti dall'applicazione.

La conferma è giunta modificando il parametro file_path per puntare a /etc/passwd, ottenendo in risposta il contenuto completo del file:

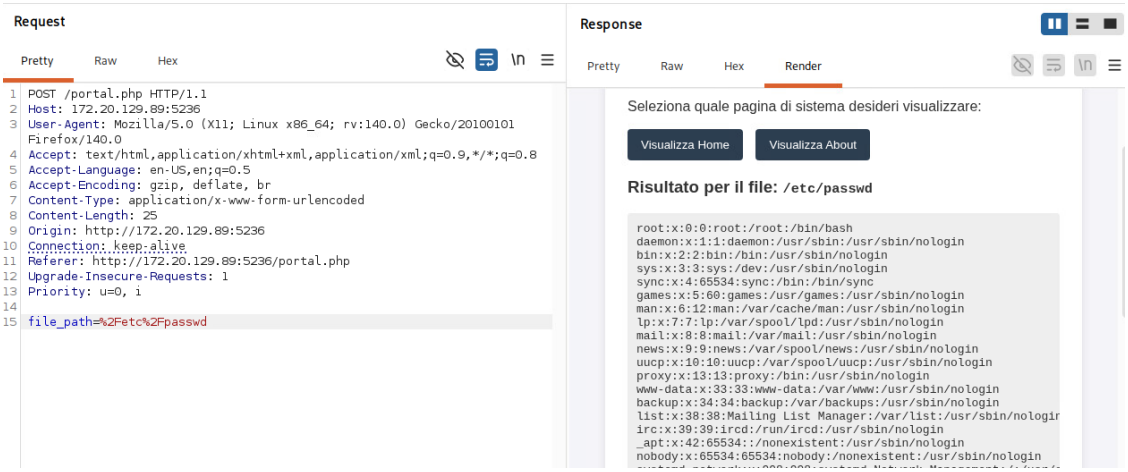


Figura 3 — Richiesta e risposta Burp Suite: lettura arbitraria di /etc/passwd tramite path traversal

5. Esfiltrazione delle credenziali

Individuata la vulnerabilità di path traversal / LFI, si è proceduto a verificare la struttura tipica del filesystem di Apache per individuare file sensibili. È stato così individuato il file .htpasswd, contenente gli hash delle password.



Figura 4 — Richiesta verso /var/www/html/.htpasswd e relativo hash della password restituito

Dalla risposta è stato ottenuto l'hash associato all'utenza student, pronto per essere sottoposto a cracking offline.

6. Cracking della password

Per craccare l'hash ottenuto è stato impiegato john the ripper. Il primo tentativo, con la wordlist rockyou.txt, non ha prodotto risultati. È stata quindi utilizzata una wordlist della suite SecLists specifica per gli hash di tipo Apache/bcrypt-like, che ha permesso di individuare la password in chiaro.

Credenziali ottenute: `student : studen1234`

7. Accesso iniziale (SSH)

Con le credenziali ottenute è stato effettuato un tentativo di accesso SSH all'host target, riuscito con successo.

Dalla home directory dell'utente, tramite il comando cat user.txt, è stata recuperata la prima flag:

```
student@CTFITS20261:~$ cat user.txt
FLAG{path_traversal_mastered_2026}
```

Flag utente: `FLAG{path_traversal_mastered_2026}`

8. Escalation dei privilegi

L'utente student non risultava presente nel file sudoers, pertanto è stata condotta un'ulteriore fase di enumerazione del filesystem alla ricerca di configurazioni deboli o mal gestite, con particolare attenzione ai crontab di sistema.

È stato individuato un task pianificato che esegue uno script con privilegi di root:

```
*  *    * * *   root    /bin/bash /usr/local/bin/system_check.sh
```

Figura 5 — Crontab di root: esecuzione periodica dello script /usr/local/bin/system_check.sh

Il file risultava avere permessi 777 ed essere di proprietà di root: ciò ha reso possibile modificarne il contenuto come utente student. È stata quindi inserita una reverse shell (generata tramite un reverse shell generator online) all'interno dello script, in attesa che il cron job la eseguisse automaticamente con privilegi elevati.

Messosi in ascolto con un listener (nc -lvnp 4444), all'esecuzione pianificata dello script è stata ricevuta una shell con privilegi di root:

```
┌──(raccis㉿kaliOFF)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.20.129.144] from (UNKNOWN) [172.20.129.89] 57856
sh: 0: can't access tty; job control turned off
# ls
root.txt
# id
uid=0(root) gid=0(root) groups=0(root)
# hostname
CTFITS20261.0
# ls
root.txt
# cat root.txt
FLAG{cron_job_priv_esc_success}
#
```

Figura 6 — Shell inversa ricevuta con privilegi uid=0(root): recupero della flag finale in root.txt

Flag root: `FLAG{cron_job_priv_esc_success}`

9. Conclusioni

La challenge ITSCTF1 è stata completata con successo, ottenendo l'accesso completo (root) all'host target. Il percorso di attacco ha sfruttato in sequenza:

- Una vulnerabilità di tipo Local File Inclusion / path traversal nel parametro file_path della pagina portal.php, usata per leggere file sensibili del server (/etc/passwd, .htpasswd).

- Il cracking offline dell'hash della password dell'utente student tramite wordlist mirata.
- L'accesso SSH con le credenziali recuperate e il reperimento della prima flag.
- Un'escalation dei privilegi sfruttando permessi errati (777) su uno script invocato da un cron job di root, sostituendolo con una reverse shell.

L'esito evidenzia come la combinazione di una validazione insufficiente dell'input utente (LFI) e di una errata gestione dei permessi sui file eseguiti da processi privilegiati (cron job root con script scrivibile da chiunque) possa portare, concatenando le due debolezze, alla compromissione totale del sistema.